

Lab 02 Template

1. Read the man pages of nmap. What nmap flag run a scan without performing a ping scan first?

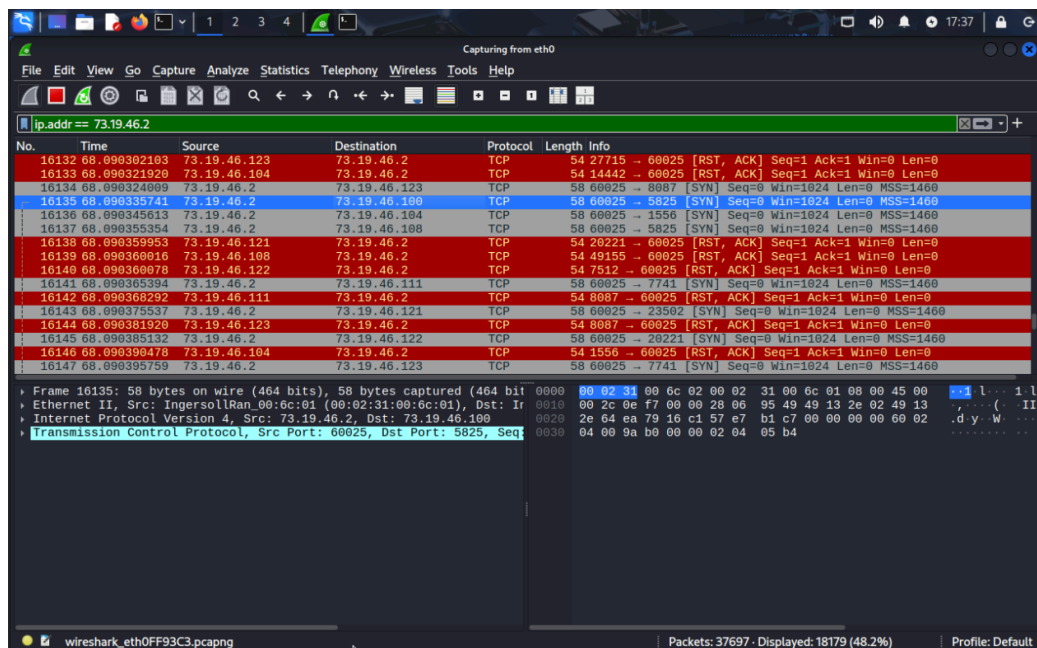
(10 points)

Ans) “-Pn” runs without performing a ping scan first.

2. Examine the Wireshark output. How many packets were generated? Why might performing this kind of scan not be a good idea?

(10 points)

Ans)



We can see that out of 37,697 packets generated in total, 18,179 were displayed for my filtered search, which means that a very high number of packets are generated, which makes it very noisy and easily detectable.

3. Submit your table for enumerating ports, services, and operating systems
(10 points)

Host	Open Ports	Services	OS Guess (1)	Reasoning	OS Guess (2)	Reasoning
73.19.46.100	135, 139, 445	msrpc, netbios-ssn, microsoft-ds	Windows XP	Microsoft-DS and NetBIOS-SSN indicate that the OS might be Windows because it is generally used by them	Same as OS (1)	Same as OS (1)
73.19.46.102	7,9,13,17,19,18,13,5,13,9,44,5,51,5,21,79,8088	echo, discard, qotd, chargen, msrpc, netbios-ssn, microsoft-ds, printer, vmrpd, radan-http	Windows (10)	Again, port numbers such as 135,139 and 445 are being used over here.Plus, the port number 3389, which is used for RDP(Remote Desktop Protocol), is a protocol that was developed by Microsoft to allow a user to connect to another computer over a network and use it as if they were using their own PC.	Same as OS (1)	Same as OS (1)
73.19.46.104	22,80,443,3306	ssh,http, https,mysql	Linux (Ubuntu)	The ports such as 22(ssh), 3306(MySQL) and	Same as OS (1)	Same as OS (1)

				80/443(Apache) are typically used for Linux database and swerver stack		
73.19.46.106	80,135,139,445	http,msrpc,netbios-ssn,microsoft-ds	Windows	Ports for Microsoft-DNS and NetBIOS-SSN are being used over here with the web service port 80, which clearly points out that Windows is the OS over here.	FreeBSD	Our nmap scan showed that port number 80 is running on version Apache httpd 2.2.9, and port number 139 is running on OpenSSH 4.5p1, which clearly indicates that the OS is FreeBSD.
73.19.46.108	135,139,445	msrpc,netbios-ssn,microsoft-ds	Windows 10	Windows ports such as NetBIOS-SSN and Microsoft-DS are being used over here	Same as OS (1)	Same as OS (1)
73.19.46.111	135,139,445,3389,5357	msrpc,netbios-ssn,microsoft-ds,ms-wbt-server,wsdapi	Windows 10	Port numbers 135,139,3389 are being used over here, which are most commonly used by Windows. These port numbers are being used with port number 5357, which is WSDAPI (a networking service that uses web	Same as OS (1)	Same as OS (1)

				service protocols to let computers and devices discover and communicate with each other on a local network.		
73.19.46.121	22,80	ssh,http	Linux (Ubuntu)	Port Number 22(ssh) is being used over here with port number 80 (http), which indicates that Linux might be the OS being used over here	Same as OS (1)	Same as OS (1)
73.19.46.122	22,8089	ssh, unknown	Linux(Ubuntu)	Port number 8089 is most often used by Splunk, and port number 22 is used by SSH, which are commonly used by Linux	Same as OS (1)	Same as OS (1)
73.19.46.123	22,10000	ssh,snet-sensor-mgmt	Linux(Ubuntu,webmin)	Port number 10000 is used by Webmin(a web-based administration tool for Linux users.	Same as OS (1)	Same as OS (1)

4. For each host, answer the following:

(10 points)

- a. Were either of your guesses accurate in guessing the OS?

Ans) Yes, all of my guesses were accurate; it's just that my first guess on the OS for host 73.19.46.106 was inaccurate; however, my second guess saved me as it proved to be the correct one.

- b. Why might it be valuable to determine operating systems without performing an nmap scan?

Ans) It might be valuable to determine the OS without performing a nmap scan because:

- Nmap scans, especially some aggressive ones, could alert the IDS/IPS, firewalls, and logging alerts.
- It takes a lot of time, so instead of that, we could just take a look at the DHCP logs or capture network traffic from Wireshark and then study it.
- Active scanning with Nmap is not even allowed on some academic or corporate networks.

5. List three ways and/or options you might use nmap, such that alarms are less likely to be raised
(10 points)

Ans) 3 ways in which we can use nmap such that alarms are less likely to be raised are:

- Decoy Scans (Command: -D): When we use this command, it just starts sending probes from multiple spoofed addresses along with our own, which makes it difficult for IPS/IDS to detect which one is the real scanner.
- Fragment Packets (Command: -f): It breaks down the probe packets into tiny IP fragments, which makes it difficult for the firewall to reassemble them, and thus these scans may not be noticed by the system.
- Source port spoofing (Command: -g): It can sometimes bypass some poor firewalls as it sends traffic as if it were a trusted port.

6. Take a screenshot of the vulnerability output from scanning X.X.X.100
(10 points)

```

--(root@kali)-[/home/cpre2310/nmap_scans]
# nmap --script smb-vuln-ms08* 73.19.46.100
Starting Nmap 7.95 ( https://nmap.org ) at 2025-09-14 17:25 CDT
Nmap scan report for 73.19.46.100
Host is up (0.0016s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
55/tcp    open  msrpc
59/tcp    open  netbios-ssn
55/tcp    open  microsoft-ds
MAC Address: 00:02:31:00:6C:02 (Ingersoll-Rand)
Host script results:
smb-vuln-ms08-067:
VULNERABLE:
Microsoft Windows system vulnerable to remote code execution (MS08-067)
State: LIKELY VULNERABLE
IDs: CVE:CVE-2008-4250
The Server service in Microsoft Windows 2000 SP4, XP SP2 and SP3, Server 2003 SP1 and SP2, Vista Gold and SP1, Server 2008, and 7 Pre-Beta allows remote attackers to execute arbitrary code via a crafted RPC request that triggers the overflow during path canonicalization.
Disclosure date: 2008-10-23
References:
https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2008-4250
https://technet.microsoft.com/en-us/library/security/ms08-067.aspx
Nmap done: 1 IP address (1 host up) scanned in 23.08 seconds
```

7. Find at least one other vulnerability using NSE and include a screenshot and a short description of the found vulnerability.
(10 points)

Ans)

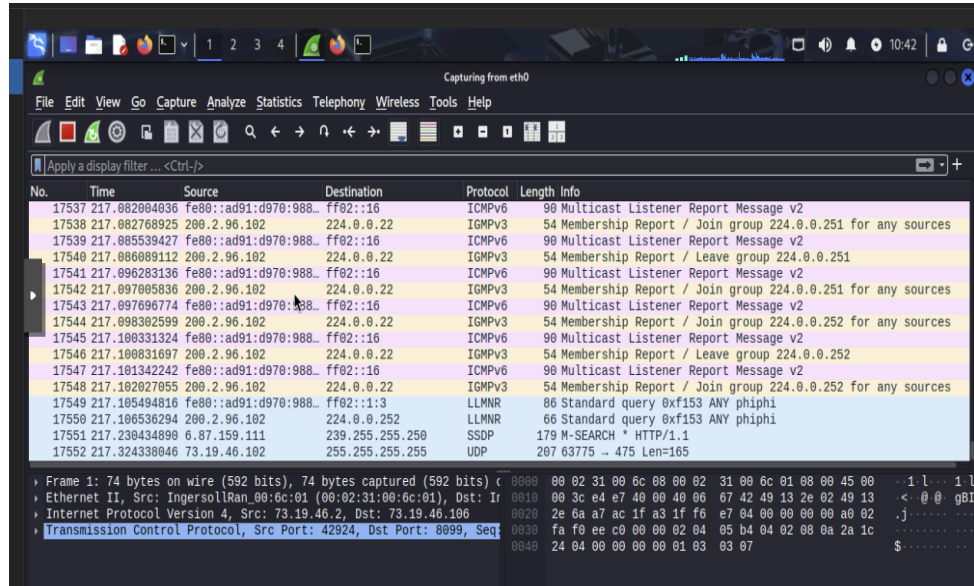
```
(root@kali)-[/home/cpre2310/nmap_scans]
# nmap --script smb-vuln-ms08* 73.19.46.111
Starting Nmap 7.95 ( https://nmap.org ) at 2025-09-14 17:56 CDT
Nmap scan report for 73.19.46.111
Host is up (0.00027s latency).
Not shown: 995 closed tcp ports (reset)
PORT      STATE SERVICE
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
3389/tcp  open  ms-wbt-server
5357/tcp  open  wsdapi
MAC Address: 00:02:31:00:6C:23 (Ingersoll-Rand)

Host script results:
| smb-vuln-ms08-067:
|   VULNERABLE:
|     Microsoft Windows system vulnerable to remote code execution (MS08-067)
|     State: LIKELY VULNERABLE
|     IDs: CVE:2008-4250
|           The Server service in Microsoft Windows 2000 SP4, XP SP2 and SP3, Server 2003 SP1 and SP2,
|           Vista Gold and SP1, Server 2008, and 7 Pre-Beta allows remote attackers to execute arbitrary
|           code via a crafted RPC request that triggers the overflow during path canonicalization.
|
|     Disclosure date: 2008-10-23
|     References:
|       https://technet.microsoft.com/en-us/library/security/ms08-067.aspx
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2008-4250
|
Nmap done: 1 IP address (1 host up) scanned in 29.24 seconds
```

I ran the additional commands on the range of IP addresses that I found, and out of those many, I found a vulnerability while scanning 73.19.46.111. It says that the Microsoft Windows system is vulnerable to remote code execution (MS08-067), which means that it allows the remote attackers to execute arbitrary code by sending a special RPC(Remote Procedure Protocol- It allows a computer to request a service or run a procedure on another computer on the same network). It usually affects Windows 2000 SP4, Windows XP SP2/SP3, and some other pre-release versions of Windows 7.

8. Look at the traffic captured in Wireshark and comment on what types of packets and different protocols are being used.
(10 points)

Ans)

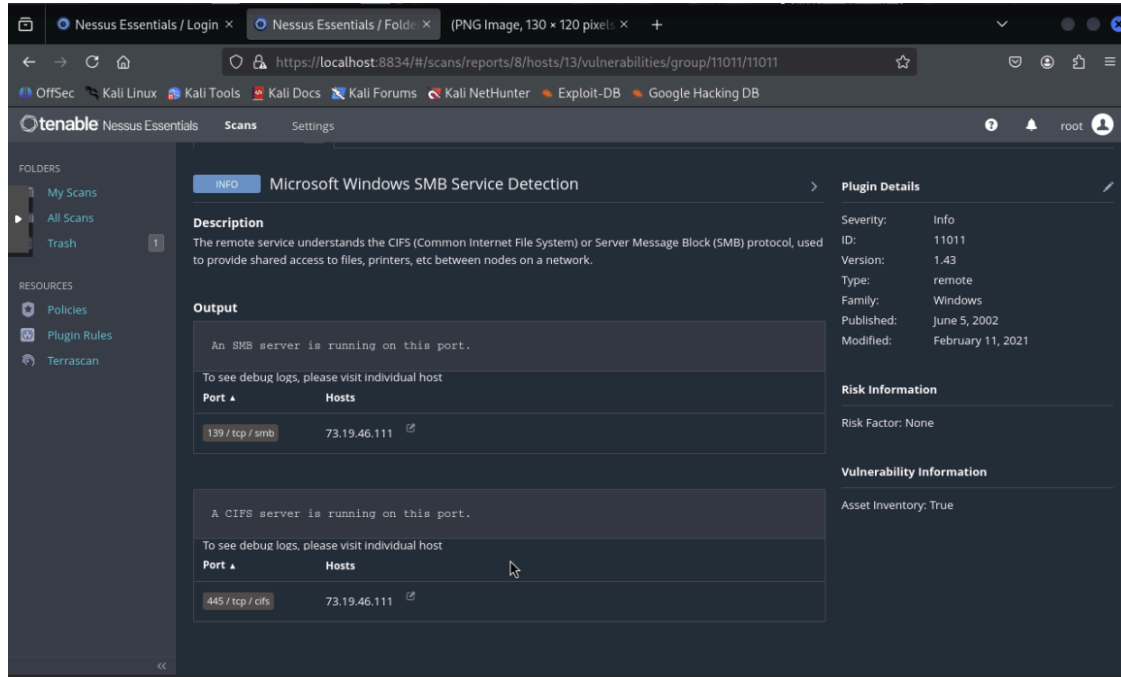


On the basis of the screenshot above, we can say that Nessus is using the following packets/protocols:

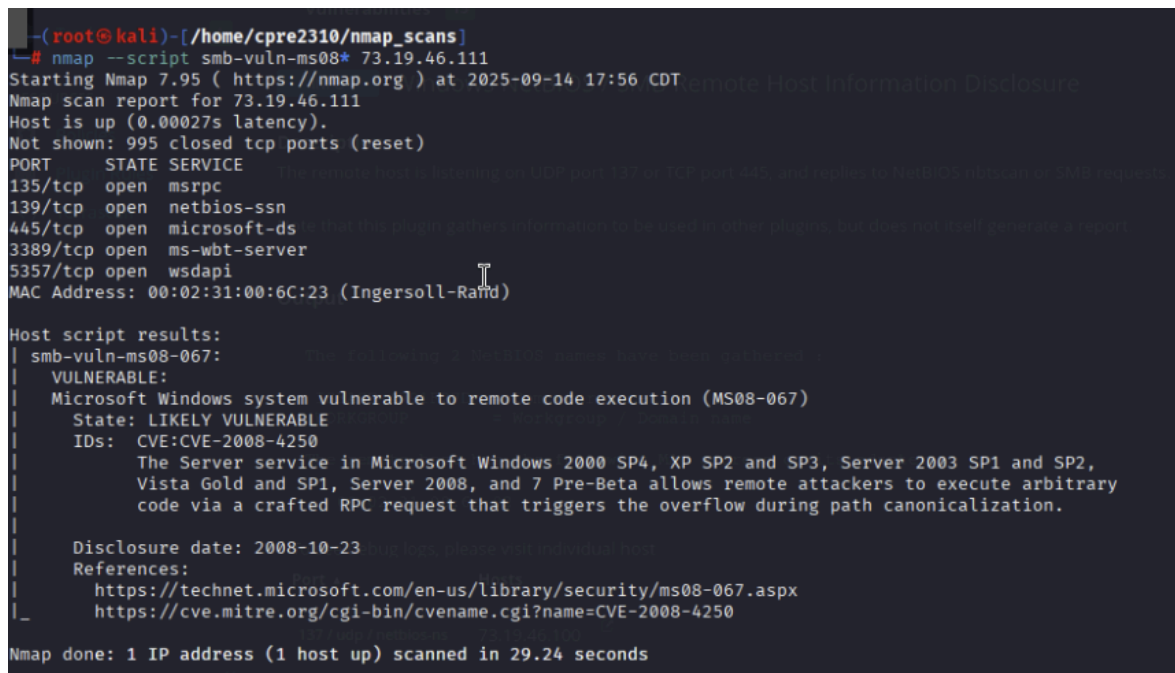
- 1) ICMPv6 packets(Multicast listener): It is usually used for discovering hosts
- 2) IGMPv3 packets(Membership report): Its job is just to allow the detection of multicast-enabled hosts.
- 3) DNS/LLMNR packets(Standard Query): It is usually used for resolving any kind of hostname, and it is also used for checking any name services.
- 4) SSDP packets(M-Search HTTP/1.1): It usually probes UPnP (It is a set of networking protocols that basically allows users to discover each other automatically and allows services such as file sharing and media streaming) devices and services.
- 5) UDP packets: It usually sends various packets to various ports to determine which ones are currently running services.

9. Comment on a vulnerability that is common between NSE and Nessus (include a screenshot to verify this common vulnerability)
(10 points)

Ans) Nessus Screenshot



Nmap Screenshot



By analyzing the screenshots above, we can say that we found a common vulnerability that is related to Microsoft's SMB service. NSE flagged out the host as likely vulnerable to MS08-067 (CVE-2008-4250), which is a critical remote code execution flaw in Windows Server Service. Nessus also confirmed this activity by detecting that the SMB services were also running on the ports 139/tcp and 445/tcp, which also included the SMB versions, which pointed towards the same vulnerability.

10. List 2-3 additional vulnerabilities that interest you and make a note of their CVE and which hosts they were found on
(10 points)

Ans)

Vulnerabilities	CVE	Hosts/Ports	Description
ICMP timestamp request Remote data disclosure	CVE-1999-0524	73.19.46.108	It basically responds to all ICMP timestamp-related requests, which reveal time and help by bypassing the time-based authentication.
Echo Service Detection	CVE-1999-0103, CVE-1999-0635	73.19.46.102	It sends back whatever data it receives, but it's not used anymore and that's why attackers can send a huge amount of requests to it, and since it responds back to all the data, it wastes a lot of resources and eventually this activity also slows down the server and sometimes it may even crash it.
Chargen UDP service Remote DoS	CVE-1999-0103	73.19.46.102	Since it responds to random characters when it comes across any data, attackers tend to send many fake requests, which in return floods the data with junk

			requests and cause Denial of Service by slowing down or even crashing the server at times.
--	--	--	--